CS 448/548 Network Security
Midterm Exam

By signing my name below, I certify that I have acknowledged the Student Honor Code of the University of Alabama. I will work on this exam independently without discussing exam questions with any people in or outside of class.

This exam consists of six pages, including one cover page (first), one reference page (last), and four pages of questions. (Q1 T/F 15pt; Q2 Single-answer multiple choice 10pt; Q3 Multiple-answer 15pt+3pt bonus; Q4 AES-GCM 21pt; Q5 Kerberos 24pt; Q6 VPN 15pt)

Write **brief bullet-point answers** that include only the **key terms/steps** needed for full credit (e.g., security property + mechanism + key/field name); avoid long explanations as **grading is based on presence of key information, not length.**

Name: _____

CWID: _____

Date: _____

1. True (T) or False (F) (15pt)

F	1. RSA signatures sign *hash(m)* with the public key and verify using the private key.
T	2. Symmetric cryptography generally requires less computation than asymmetric cryptography.
F	3. AES-CBC (Cipher Block Chaining) alone provides message integrity.
T	4. Reusing nonce values will compromise the security of AES-GCM.
F	5. Data integrity is the protection of data from unauthorized disclosure.
T	6. The official withdrawal of DES as a standard was primarily due to small key length.
T	7. The strength of an ideal hash function against brute-force attacks depends solely on the length of the hash code produced by the algorithm
F	8. In Kerberos, mutual authentication between service server and client can be achieved when the service server proves knowledge of the client's long-term key (*Kc*).
F	9. Kerberos relies on both symmetric and asymmetric encryption.
F	10. In Kerberos, the Ticket-Granting Ticket (TGT) is encrypted with the long-term key of Authentication Server (AS).
T	11. IPsec provides security at Layer 3, so it can protect traffic regardless of the transport/application protocol.
F	12. Using a VPN (tunnel mode) can eliminate all traffic-flow metadata (source/destination address, timing, volume) leakage.
T	13. Proxy firewalls inspect payload content up to the application layer.
F	14. In OAuth 2.0, the access token is primarily used to authenticate the user to the client application.
F	15. The collision security level of SHA-512 is 512-bit.

2. Single-Answer Multiple Choice (10pt) (Select **one best** answer)

1) Which of the following is widely **today** used for Diffie-Hellman key exchange. c_____

a. AES b. RSA c. ECC d. SHA

2) OpenID Connect is best described as:____b_____

a. An authorization protocol replacing OAuth 2.0
b. An identity layer on top of OAuth 2.0 that provides an ID token
c. A symmetric-key enterprise protocol using tickets
d. A password storage standard

3). What is the primary role of the Ticket-Granting Server (TGS) in Kerberos? ___b_____

a. Authenticate users' passwords b. Issue service tickets
c. Issue ticket granting tickets d. Generate public/private key pairs

4). Which IPsec mode can encrypt the **inner** IP header to evade destination-address-based egress filtering in the Firewall? ____a_____

a. Tunnel mode b. Transport mode c. Both Tunnel and Transport mode d. Neither

5). Which property of a secure hash prevents an attacker from finding any two distinct messages with the same digest?_____c_____

a. One-way resistant b. Weak collision resistant c. Strong collision resistant d. None of them

3. Multiple-Answers (15pt+3 Bonus pt) (Select all that apply)

1) Select the security service provided by TLS.____abd___

a. Confidentiality b. User authentication c. Access control d. Key exchange

2) What advantages does AES-CTR, when functioning as a stream cipher, offer compared to AES block cipher modes? _____ad____

a. Encrypting data by XOR with a keystream b. Higher level of security

c. Lower computation complexity d. Without the need for padding

3) In Kerberos, which is true about Kc:_____bc____

a. Randomly generated using public key cryptography
b. Derived from the user's password
c. Long term key
d. Shared with the KDC (key distribution center) and SS (service server)

4) Which mechanisms help reduce **replay** risk in Kerberos?bc____

a. Session key
b. Ticket lifetimes (expiration)
c. Encrypting the authenticator containing timestamps
d. Include client identity and network address in Ticket

5) Which security services are provided by IPsec?__abc___

a. Confidentiality b. Data integrity c. Anti-replay d. Nonrepudiation

6) (Bonus) Which of the following can evade destination-IP-based filtering at host? _____ad____

a. VPN b. IPsec Transport mode c. SSH tunneling d. TLS Proxy

4. (21pt) Refer to the following AES-GCM diagram (blocks (1)–(3)).

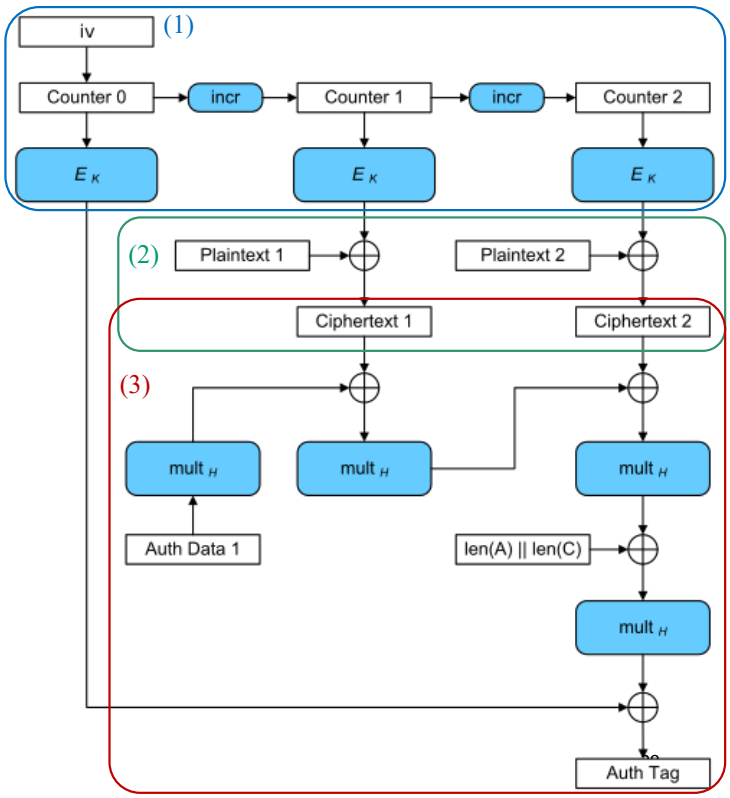
(9pt) Block (1): What is the **purpose of this block**? Explain the roles of the **IV** and the **incrementing counter** in the diagram. Your answer should address: why IV must be **unique per key**, and what the counter is used for.

Generate keystream

IV: random, unique for each session, avoid key reuse among sessions

Incremental counter: changing AES input for each block, avoid key reuse among blocks

(6pt) Block (2): What does this block compute? What security services provided by this block?
Encryption; security service: Confidentiality

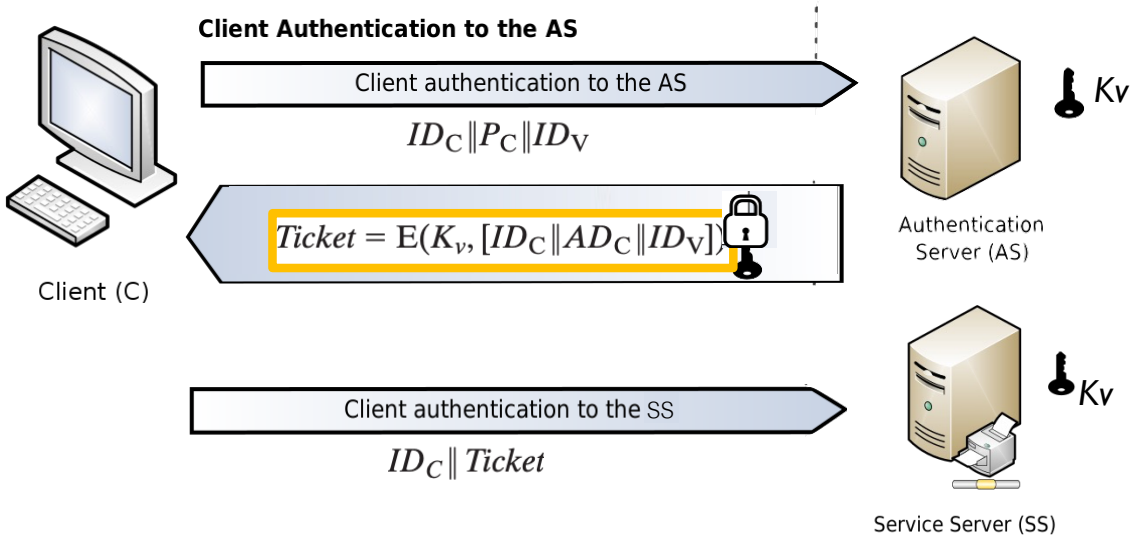


(6pt) Block (3): What does this block compute? What security services provided by this block?

Calculate of Message authentication code (MAC)

Data/Message (origin) authentication

5. (25pt) The figure shows a simplified Kerberos-like authentication design. Compared with the standard Kerberos design (see reference page), identify **four** distinct security flaws. For each issue, briefly state why it is a problem.



1) Password Pc sent in plaintext, no protection (password leakage)
2) No KGS, send credential for each service (no SSO, increase risk of credential leakage)
3) No timestamp and lifetime in Ticket (ticket reuse)
4) No short-term session key for connection confidentiality
5) No authenticator from C to SS (replay attack)
6) No mutual authentication (C cannot verify identity of AS and SS)

6. (15pt) Assume a client C accesses a destination server S. A VPN gateway V is used when the VPN is enabled. Consider the following information items

a. client IP address
b. destination server IP address
c. VPN gateway public IP address
d. traffic metadata: timing / packet sizes / total bytes (**timing/volume**)

For each scenario below, indicate which items (a-d) are observable by the specified party. (Select all that apply.)

No VPN: what can an on-path observer between C and S observe?

a, b, d

No VPN: what can the destination server S observe?

a, b, d

VPN enabled: what can an on-path observer between C and V observe?

a, c, d

VPN enabled: what can the VPN gateway V observe?

a, b, c, d

VPN enabled: what can the destination server S observe?"

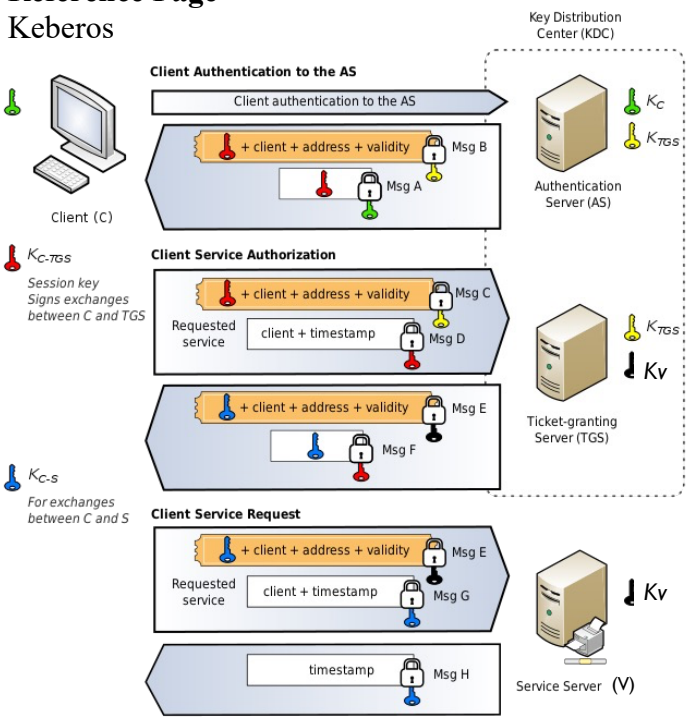
b, c, d

CS 448/548 Midterm Exam

Your name: _____

Reference Page

Keberos



$$C \rightarrow AS: ID_c || ID_{tgs} || T_1$$

$$AS \rightarrow C: E(K_c, [K_{c,tgs} || ID_{tgs} || T_2 || Ticket_{tgs}])$$

$$Ticket_{tgs} = E(K_{tgs}, [K_{c,tgs} || ID_c || AD_c || ID_{tgs} || TS_2 || Lifetime])$$

$$C \rightarrow TGS: ID_v || Ticket_{tgs} || Authenticator$$

$$Authenticator = E(K_{c,tgs}, [ID_c || AD_c || TS_3])$$

$$TGS \rightarrow C: E(K_{c,tgs}, [K_{c,v} || ID_v || T_4 || Ticket_v])$$

$$Ticket_v = E(K_v, [K_{c,v} || ID_c || AD_c || ID_v || TS_4 || Lifetime])$$

$$C \rightarrow V: Ticket_v || Authenticator$$

$$Authenticator = E(K_{c,v}, [ID_c || AD_c || TS_5])$$

$$V \rightarrow C: E(K_{c,v}, [T_5 + 1])$$

Security Services:

AUTHENTICATION

The assurance that the communicating entity is the one that it claims to be.

Peer Entity Authentication
Used in association with a logical connection to provide confidence in the identity of the entities connected.

Data-Origin Authentication
In a connectionless transfer, provides assurance that the source of received data is as claimed.

ACCESS CONTROL

The prevention of unauthorized use of a resource (i.e., this service controls who can have access to a resource, under what conditions access can occur, and what those accessing the resource are allowed to do).

DATA CONFIDENTIALITY

The protection of data from unauthorized disclosure.

Connection Confidentiality
The protection of all user data on a connection.

Connectionless Confidentiality
The protection of all user data in a single data block

Selective-Field Confidentiality
The confidentiality of selected fields within the user data on a connection or in a single data block.

Traffic-Flow Confidentiality
The protection of the information that might be derived from observation of traffic flows.

DATA INTEGRITY

The assurance that data received are exactly as sent by an authorized entity (i.e., contain no modification, insertion, deletion, or replay).

Connection Integrity with Recovery
Provides for the integrity of all user data on a connection and detects any modification, insertion, deletion, or replay of any data within an entire data sequence, with recovery attempted.

Connection Integrity without Recovery
As above, but provides only detection without recovery.

Selective-Field Connection Integrity
Provides for the integrity of selected fields within the user data of a data block transferred over a connection and takes the form of determination of whether the selected fields have been modified, inserted, deleted, or replayed.

Connectionless Integrity
Provides for the integrity of a single connectionless data block and may take the form of detection of data modification. Additionally, a limited form of replay detection may be provided.

Selective-Field Connectionless Integrity
Provides for the integrity of selected fields within a single connectionless data block; takes the form of determination of whether the selected fields have been modified.

NONREPUDIATION

Provides protection against denial by one of the entities involved in a communication of having participated in all or part of the communication.